Seguridad: matrices OWASP y Ley 21.663

Cada control se **demuestra con pruebas automatizadas** (carpeta `tests/`). `vendor/bin/phpunit` debe pasar completo.

1. OWASP Top 10:2025

ID	Categoría	Controles implementados	Prueba(s)
A01	Control de acceso rota	Policies (`ExpedientePolicy`, `DocumentoPolicy`) + middleware de rol. El **admin no lee expedientes**; el auditor es solo lectura; el funcionario solo su unidad o participación (derivación/firma). IDOR: solicitud siempre por `folio` **y** RUN de sesión; archivos verificados contra su expediente; descarga ciudadana solo con notificación *enviada*. Sin SSRF: endpoints externos fijos, sin redirecciones, timeouts.	`SeguridadHttpTest::test_control_de_acceso_exped` `test_idor_*`, `ReglasFirmaTest::test_solo_el_alcalde_crea_dele` `FirmaGobClienteTest::test_no_sigue_redireccione`

ID	Categoría	Controles implementados	Prueba(s)
A02	Configuración de seguridad incorrecta	`APP_DEBUG=false`; páginas de error genéricas; **CSP** `default-src 'self'; script-src 'self'; frame-ancestors 'none'; form-action 'self'; base-uri 'none'; object-src 'none'`; HSTS, `nosniff`, `Referrer-Policy`, `Permissions-Policy`; `Cache-Control: no-store` en contenido autenticado; `.htaccess` (HTTPS, dotfiles, extensiones, `Indexes`). **Falla cerrada en producción** (`ProductionGuard`).	`test_cabeceras_*`, `test_paginas_sin_scripts_en_li` `test_cache_control*`, `test_produccion_falla_cerra` `test_pagina_de_error_generica*`, `test_dotfiles*`
A03	Fallas en la cadena de suministro	Todo autoalojado (gob.cl, fuentes, TinyMCE, jQuery/Bootstrap; **sin CDN**); dependencias mínimas (HTMLPurifier, Dompdf, chillerlan/php-qrcode; Gmail/FirmaGob/ClaveÚnica con el cliente HTTP de Laravel, sin SDKs); `composer.lock` versionado; `composer audit` limpio; **SBOM** CycloneDX `docs/sbom.cdx.json`.	CSP sin orígenes externos (test), `composer audit`

ID	Categoría	Controles implementados	Prueba(s)
A04	Fallas criptográficas	Archivos cifrados con **libsodium XChaCha20-Poly1305**, nonce aleatorio de 24 bytes, **SHA-256 del contenido como datos asociados** y verificación al leer; nombres aleatorios; claves con id y rotación (`FILE_ENCRYPTION_KEYS`); sesión: token de 256 bits (Laravel 40 chars alfanum ≈ 238 bits + `state` ClaveÚnica de 256 bits), solo hash SHA-256 en BD; comparaciones con `hash_equals`; HMAC-SHA256 en auditoría; JWT HS256/RS256 estándar; TLS obligatorio.	`FileVaultTest`, `test_sesion_en_bd_guarda_solo_el_` `test_login_state*`

ID	Categoría	Controles implementados	Prueba(s)
A05	Inyección	Solo Eloquent/Query Builder parametrizado (búsquedas con `LIKE` escapado); Blade con escape automático (único `{!! !!}`: HTML ya sanitizado por HTMLPurifier); **HTMLPurifier** con lista blanca estricta; subidas validadas **por contenido** (firma binaria), solo PDF/JPG/PNG/TIFF, rechazo de `/JavaScript /JS /Launch /EmbeddedFile /RichMedia /OpenAction` (incluida evasión `#hex`), límites de tamaño/cantidad, almacenamiento fuera del docroot, `Content-Disposition` + `nosniff`, rutas validadas por regex (sin path traversal); asunto/destinatario de correo validados contra inyección de cabeceras.	`HtmlSanitizerTest`, `UploadValidatorTest`, `SubidasHt` `FileVaultTest::test_path_traversal*`, `GmailTransportTest::test_rechaza_inyeccion*`, `tes` `TramitesYMantenedoresTest::test_campos_de_combi`

ID	Categoría	Controles implementados	Prueba(s)
A06	Diseño inseguro	Rate limiting (login 10/min, envío 10/min, consulta pública 30/min, firma 10/min, LLM 6/min y 30/día, correo 20/min); límites de campos; **máquinas de estado** (documento: borrador→en_flujo→vigente; no se edita en flujo/vigente); turnos estrictos; idempotencia de `finalizar`; transacciones con rollback (el correlativo se revierte si falla); una persona no puede visar y firmar.	`test_rate_limit*`, `ReglasFirmaTest`, `CorrelativoTes` `CorrelativoConcurrenciaTest`
A07	Fallas de autenticación	Solo ClaveÚnica; `state` de un solo uso; **cookie `__Host-sgd_session` `HttpOnly; Secure; SameSite=Lax`**; sesión nueva en login (anti fijación); expiración por **inactividad 30 min** y **absoluta 8 h**; sesiones en BD con hash; **CSRF** obligatorio; funcionario debe existir y estar activo (revalidado en cada petición); OTP de firma nunca almacenado ni registrado.	`test_cookie_de_sesion*`, `test_sesion_expira*`, `test` `test_funcionario_debe_existir*`, `test_usuario_des` `test_csrf_obligatorio*`, `ReglasFirmaTest::test_ot`

ID	Categoría	Controles implementados	Prueba(s)
A08	Fallas de integridad de software y datos	Bitácora **append-only con cadena HMAC-SHA256** (cada registro incluye el hash del anterior; `audit:verify` y panel `/app/seguridad`); bloqueo a nivel de modelo **y de BD** (triggers; GRANT sin UPDATE/DELETE documentado); versiones de documento inmutables (modelo + trigger); SHA-256 por documento verificado al leer; `checksum_original` de FirmaGob verificado contra el enviado.	`AuditoriaTest`, `ReglasFirmaTest::test_versiones_i` `FirmaGobClienteTest::test_checksum*`

ID	Categoría	Controles implementados	Prueba(s)
A09	Fallas de registro y alertas	Se auditan login/logout/fallos, accesos a expedientes y archivos (marcando sensibles), firmas, CSRF fallidos, accesos denegados (403), errores 500, consultas públicas, cambios de mantenedores, exportaciones, envíos de correo (solo metadatos). Secretos y OTP **redactados**. Panel `/app/seguridad` (admin/auditor) con verificación de cadena e **incidentes** con hitos CSIRT. Verificación nocturna (`audit:verify`).	`AuditoriaTest::test_no_registra_secretos*`, `test_csrf_obligatorio*`
A10	Manejo inadecuado de condiciones excepcionales	Falla cerrada: si FirmaGob/Gmail/Casilla fallan el flujo **no avanza** ni se pierde estado; `finalizar` reintentable e idempotente; correo → *fallida* con reintentos; mensajes sin detalles internos; limpieza de archivos huérfanos ante rollback.	`ReglasFirmaTest::test_otp_fallido*`, `GmailTransportTest::test_fallo_*`, `FirmaGobClienteTest::test_checksum_distinto_err`

2. OWASP Top 10 for LLM Applications 2025 (asistente de redacción, apagado por defecto)

ID	Riesgo	Control	Prueba
LLM01	Inyección de prompt	Contenido del expediente enviado como dato delimitado `<datos_no_confiables>` (se neutraliza cualquier intento de cerrar el delimitador); **sin herramientas**; heurística de inyección con advertencia visible.	`LlmTest::test_contenido_delimitado*`
LLM02	Divulgación de información sensible	Redacción previa de RUN, correos y teléfonos; se envía solo el texto del borrador (no metadatos, folio ni expediente).	`test_redaccion_previa*`
LLM03	Cadena de suministro	Una única API HTTPS fija (`api.anthropic.com`), sin plugins ni modelos locales.	`test_contenido_delimitado*` (URL fija)
LLM04	Envenenamiento de datos/modelo	Sin entrenamiento ni *fine-tuning* con datos ciudadanos.	Diseño (no hay código de entrenamiento)
LLM05	Manejo inadecuado de salida	La salida se trata como texto no confiable: se **escapa por completo y se sanitiza** (HTMLPurifier); jamás se inserta sola.	`test_salida_no_confiable*`

ID	Riesgo	Control	Prueba
LLM06	Agencia excesiva	Sin agencia: requiere acción humana "Insertar"; el asistente nunca guarda ni firma.	`test_el_asistente_no_guarda_nada*`
LLM07	Filtración del prompt de sistema	El prompt de sistema no contiene secretos ni datos internos.	`test_contenido_delimitado*` (system sin clave)
LLM08	Debilidades de vectores/embeddings	Sin RAG ni embeddings con datos ciudadanos.	Diseño
LLM09	Desinformación	Aviso de revisión humana y prohibición de inventar normas/numeración (`[COMPLETAR]`).	`test_contenido_delimitado*`
LLM10	Consumo desmedido	Tope de entrada (≈6.000 caracteres) y salida (800 tokens), **6/min y 30/día por usuario**, timeouts.	`test_tope_de_entrada`, `test_limite_de_6_por_minuto*`

3. Correspondencia con la Ley 21.663

Obligación / principio de la ley	Medida en el SGD
Gestión de riesgos y medidas de seguridad proporcionales	Esta matriz; mínimo privilegio; falla cerrada.
Prevención y resistencia (principio de seguridad por diseño)	CSP estricta, CSRF, validación por contenido, cifrado en reposo.
Trazabilidad y registro	Bitácora append-only con cadena HMAC verificable.

Obligación / principio de la ley	Medida en el SGD
Detección y respuesta a incidentes	Panel de incidentes, `audit:verify` diario, plan `docs/INCIDENTES.md`.
Reporte al CSIRT Nacional/ANCI	Registro de hitos (alerta temprana, 2.º reporte, informe final); **plazos A VALIDAR**; el reporte es manual por el CSIRT/encargado.
Protección de datos personales y confidencialidad	Cifrado de archivos, correos sin adjuntos ni datos sensibles, redacción previa en LLM, minimización en logs.
Continuidad y recuperación	Plan de respaldo/restauración (README), cola con reintentos idempotentes.
Cadena de suministro	SBOM, `composer audit`, sin CDN.

4. Limitaciones conocidas (resumen; ver `LIMITACIONES.md`)

- `style-src 'unsafe-inline'` es necesario para TinyMCE (los **scripts** en línea sí están prohibidos).
- Privilegio `TRIGGER` / `GRANT` por tabla puede no existir en hosting compartido: la inmutabilidad de la BD queda respaldada por el modelo y por la **detección** (cadena HMAC), no por prevención total ante un atacante con acceso directo a MySQL.
- Los archivos se cifran en memoria (máx. 10 MB por archivo).
- El control de `session` ata `last_seen` a la sesión; no hay bloqueo de sesiones concurrentes.
- Sin antivirus/ClamAV (no disponible en hosting compartido): la validación es estructural por firma binaria.
- Ley 21.663: plazos de reporte y obligaciones por tipo de sujeto **A VALIDAR**.

5. Interoperabilidad (PISEE, Codificador, DocDigital)

Riesgo	Control
A01 / SSRF	URLs de nodo, Codificador y DocDigital **fijas por `.env` y https**; servicios PISEE en **lista blanca** administrada con ruta relativa validada (sin esquema/host/`..`///); sin redirecciones; timeouts; sin SSRF por parámetros de usuario.

Riesgo	Control
A01 / minimización	PISEE solo consulta el **RUN del solicitante del expediente**, con **finalidad obligatoria**, sol el funcionario con acceso operativo (ni admin ni auditor); resultado **cifrado** y marcado sensible; la bitácora registra servicio/estado, **nunca** el resultado. DocDigital entrante solo visible a la unidad receptora y al auditor.
A04	mTLS hacia el nodo PISEE con verificación del servidor siempre activa; archivos entrantes/salientes cifrados en reposo.
A05	Subidas de DocDigital validadas por contenido (PDF sin JS/EmbeddedFile…); CSV del Codificador UTF-8, ≤5 MB, códigos con patrón estricto; asunto sin CR/LF.
A06	Estados *pendiente/enviada/fallida*, evidencia obligatoria, idempotencia y reintentos por cola; sin duplicar comunicaciones; DocDigital en modo API exige PDF con **FEA real** (nunca firma simulada).
A02	`ProductionGuard` prohíbe `DOCDIGITAL_MODE=mock/demo`, `PISEE_MODE=mock`, nodo PISEE no-https y DocDigital prod sin URL/token.
A09	Auditoría de `pisee.consulta`, `docdigital.crear/enviada/fallo/evidencia/descarga/sincronizar/entrante_rechaza` , `codificador.carga`.
A06/A10	Recepción: comunicación + archivo cifrado + expediente en **una transacción** (si falla, se borra el archivo y no queda nada); sin unidad de recepción válida no se almacena nada; acus y respuesta con estados explícitos; sin acuse no se redacta respuesta.
A01	El expediente entrante solo lo ven la unidad receptora, quienes reciben derivación o firman y el auditor; el acuse y el despacho exigen acceso operativo (ni admin ni auditor).

6. Administración (apariencia, menú, APIs, folios, firmas, repositorio, roles, logs, sesiones)

Control	Implementación	Prueba

A01 · mínimo privilegio	Catálogo de permisos (`App\Support\Permisos`); middleware `permiso:` en rutas y `permiso()` en acciones. Un rol personalizado hereda las invariantes de su **rol base** y **nunca** supera su techo; `roles.gestionar` y `delegaciones.crear` son exclusivos de roles del sistema. Roles inactivos o inexistentes no otorgan nada.	`AdministracionAccesoTest`
A01 · resguardos de cuentas	No se puede desactivar la propia cuenta ni al último administrador activo; al cambiar rol/estado se **cierran las sesiones** del usuario.	`test_resguardos_*`, `test_desactivar_o_cambiar_rol_*`
A03 · logo	Solo PNG/JPG/WebP por **contenido**, ≤1 MB, dimensiones acotadas, **re-codificado con GD** (elimina metadatos y carga incrustada), almacenado fuera del docroot con verificación de integridad (SHA-256) y servido con `nosniff`. SVG rechazado (puede contener scripts).	`AparienciaMenuTest`
A03 · colores/CSS	Solo `#RRGGBB` validado; el CSS dinámico se genera de valores validados (sin inyección). Contraste mínimo 4,5:1 en cada par texto/fondo.	`test_css_dinamico_*`, `test_contraste_*`

A03 · enlaces	Pie y menú: solo rutas internas `/…` o `https://` sin credenciales; se rechazan `javascript:`, `data:`, `http:`, `//host`. Externos con `rel="noopener noreferrer"`.	`test_validacion_de_enlaces_del_pie`
A02 · secretos de APIs	Nunca se muestran; los ingresados desde el panel se guardan cifrados con APP_KEY (`SGD_API_SECRETOS_EN_BD=1`, por defecto; en 0 solo `.env`). URLs https con protección SSRF; `ProductionGuard` se evalúa **después** de aplicar la configuración.	`ApiConfigRepositorioHttpTest`
A02 · Drive	Contenido **cifrado antes de subir**; cuenta de servicio con clave fuera del docroot; verificación md5 de extremo a extremo; el original local se borra solo después de registrar la reubicación verificada.	`RepositorioDriveTest`
A09 · logs	`audit_log` append-only con HMAC; RUN enmascarado en pantalla; exportación CSV **auditada** (sensible) y con neutralización de fórmulas; log de aplicación solo para `diagnostico.ver` y **redactado** (RUN, correos, tokens, rutas).	`test_exportar_csv_*`, `test_log_de_aplicacion_*`

A07 · sesiones	Vista de sesiones sin exponer tokens (la BD guarda solo el hash); cierre forzado auditado; la propia sesión no se cierra desde la lista; `unserialize` con `allowed_classes=false`.	`test_cierre_forzado_*`, `test_payload_malicioso_*`
Folios	Contadores atómicos con bloqueo; `documentos.folio` inmutable con unicidad `(tipo, folio)`; el contador solo se ajusta al alza.	`FoliosTest`
A03 · HTML del editor	`HtmlSanitizer` con lista blanca ampliada (tablas, imágenes, colores, tipografías de lista fija, `page-break-*`); sin `iframe`, `svg`, formularios ni `<style>`; `style` limitado a propiedades permitidas; **imágenes solo de la biblioteca interna** (`/app/recursos/N`): se eliminan URL externas, `data:` y otras rutas.	`PlantillasTest::test_el_sanitizador_*`
A01 · visibilidad de formatos	Una plantilla es visible según su alcance (toda la municipalidad o unidades marcadas); el acceso directo a una no visible responde 404; al crear un documento se valida visibilidad y tipo (antes se tomaba la primera del tipo).	`test_visibilidad_por_direccion_*`, `test_el_documento_solo_se_crea_*`

A05 · subida de imágenes	Validación por contenido (PNG/JPG/WebP), ≤2 MB, ≤4000×4000 y 12 Mpx, re-codificación GD, deduplicación por SHA-256, **cifrado** en el repositorio (local o Drive), entrega solo a personal autenticado con `nosniff`, límite de tasa; recursos inmutables.	`test_subida_*`, `test_el_re_codificado_*`
A08 · integridad	Versiones de plantilla inmutables con SHA-256; imágenes verificadas por SHA-256 al leerlas; en PDF se incrustan como data URI (una imagen alterada o inexistente se omite).	`test_crear_editar_y_versionar_*`, `test_las_imagenes_se_incrustan_*`
A08 · firmas en archivos	`FirmaPdfInspector` verifica en PHP puro (sin programas externos) el `ByteRange`, el `messageDigest` y la firma con la clave del certificado; detecta alteración, contenido agregado tras firmar y firmas que no corresponden al certificado; los PDF se guardan sin modificar. La confianza del emisor solo se afirma con CA configuradas.	`FirmaElectronicaArchivosTest`
A09 · consumo de recursos	Panel solo lectura (permiso `recursos.ver`, solo administración), sin ejecutar programas ni exponer rutas, nombres de equipo ni secretos; muestras históricas depuradas a 35 días.	`SistemaRecursosComponentesTest`

A03 · cadena de suministro	Inventario vivo de paquetes (con licencia), activos front-end (con SHA-256) y verificación automática de **recursos externos/CDN** en vistas, CSS y JS; CSP vigente visible; exportación JSON auditada (`componentes.ver`: administración y auditoría).	`test_no_hay_cdn_en_el_sistema`, `test_detecta_recursos_externos_inyectados`
A09 / privacidad · conexiones	Contadores por hora (IP o host de destino, tipo de ruta, aciertos/errores): **sin URL, parámetros, cabeceras ni contenido**; conteo posterior a la respuesta y a prueba de fallos; solo `conexiones.ver` (administración y auditoría); retención configurable con depuración diaria; geolocalización 100 % local.	`ConexionesMapaTest`

A03/A05 · código malicioso en plantillas, documentos e IA	**Defensa en profundidad en 5 capas:** (1) el editor no es de confianza; (2) HTMLPurifier con lista blanca al guardar; (3) filtro posterior (solo imágenes de la biblioteca interna, sin enlaces `//host`, sin caracteres bidireccionales/invisibles) y **red de seguridad** que reduce a texto cualquier marcado peligroso residual; (4) **nueva sanitización al mostrar** (pantalla, editor, vista previa y PDF), de modo que datos alterados directamente en la BD tampoco se ejecutan; (5) la vista previa de IA en el navegador se construye con un analizador inerte y lista blanca. La salida de la IA se **escapa por completo** (nunca HTML crudo), se detecta marcado/enlaces/invisibles y se **advierte y audita** (`llm.salida_sospechosa`, sin guardar el contenido). Las expresiones de servidor (`{{ }}`, `@php`, `<?php`) en plantillas son texto inerte.	`CodigoMaliciosoTest` (≈ 77 ataques × 5 rutas)

Gestión de trámites por dirección (v3)

Controles del módulo `/app/tramites` y sus pruebas (`GestionTramitesTest`, `scripts/qa-tramites.cjs`); el análisis OWASP Top 10 y LLM Top 10 completo está en `docs/PENTEST.md` §9.

- **Acceso:** `tramites.gestionar` y `tramites.publicar` son permisos opcionales (solo administrador por defecto); alcance por dirección aplicado en la consulta (ajeno = 404); campos de administración (dirección propietaria, CPAT, código) ignorados a no administradores. Prueba:

`test_matriz_de_permisos_por_rol`, `test_ambito_por_direccion_y_anti_idor`, `test_anexos_de_otro_tramite_no_se_pueden_secuestrar`.

- **Integridad:** máquina de estados con bloqueo de fila; versiones inmutables; auditoría de cada evento. Prueba: `test_versiones_inmutables_y_auditoria`, `test_auditoria_registra_eventos`.
- **Inyección/XSS:** textos planos, sin invisibles/bidi, escapados al mostrar. Prueba: `test_xss_e_invisibles_en_textos_se_neutralizan`, `test_direcciones_web_en_el_texto_generan_advertencia_sin_enlace`.
- **LLM:** los datos de trámites nunca llegan al asistente. Prueba: `test_llm_nunca_recibe_datos_de_tramites`.